
SendCUIEmail Development Team
Software Engineering

DATE: January 21, 2026

TO: Project Record

SUBJECT: Password/Key Transmission Requirements per NIST Guidelines

OFFICE OF PRIMARY RESPONSIBILITY: SendCUIEmail Project

1. **Purpose**

This memorandum documents NIST requirements for encryption key and password transmission, explains why SendCUIEmail exists, and provides guidance on when certificate-based encryption should be used instead.

2. **Background**

SendCUIEmail provides password-based file encryption for situations where certificate-based encryption is not feasible. This document clarifies when each approach is appropriate and the security implications of password transmission methods.

3. **NIST Guidance on Out-of-Band Authentication**

NIST SP 800-63B Section 5.1.3.1 explicitly states:

“Methods that do not prove possession of a specific device, such as voice-over-IP (VOIP) or email, **SHALL NOT** be used for out-of-band authentication.”

An out-of-band authenticator is defined as:

“A physical device that is uniquely addressable and can communicate securely with the verifier over an **independent communications channel**.”

Acceptable Out-of-Band Channels:

- SMS to mobile phone (proves possession of SIM card)
- Voice call over PSTN (Public Switched Telephone Network)
- In-person delivery
- Encrypted instant messaging (if it proves device possession)

NOT Acceptable Out-of-Band Channels:

- Email (does not prove device possession)
- VoIP (does not prove device possession)
- Same communication channel as encrypted data

4. Security Hierarchy for CUI Email Transmission

The following table presents the security options in order of preference:

Rank	Method	Description
1	S/MIME (PIV/CAC to PIV/CAC)	Both parties have smart cards. Email signed with sender's private key, encrypted with recipient's public certificate. Gold standard.
2	Hybrid (SendCUIEmail + S/MIME password)	Files: AES-256 password-encrypted. Password: S/MIME encrypted email. Compliant when recipient has PIV/CAC.
3	SendCUIEmail + Out-of-band password	Files: AES-256 password-encrypted. Password: Phone/SMS/in-person. Compliant per NIST 800-63B.
4	SendCUIEmail + Unencrypted email password	NOT COMPLIANT per NIST 800-63B. Convenience feature with warnings.

Key Insight: SendCUIEmail exists for scenarios where S/MIME is not available. When both parties have PIV/CAC, native S/MIME is preferred.

5. Option 1: Native S/MIME (PIV/CAC to PIV/CAC)

When **both sender and recipient** have PIV/CAC cards, native S/MIME provides the highest security with no password transmission required:

Security Properties:

- **Confidentiality:** Encrypted with recipient's public certificate—only their PIV/CAC can decrypt
- **Authenticity:** Signed with sender's private key—proves who sent it
- **Non-repudiation:** Sender cannot deny sending (signature tied to identity)
- **Integrity:** Any tampering breaks the cryptographic signature

Implementation (Outlook):

- Compose email with CUI files attached
- Click **Sign** (uses your PIV/CAC private key)

- (c) Click **Encrypt** (uses recipient's public certificate)
- (d) Send

When to Use:

- Both parties have PIV/CAC with valid certificates
- Recipient's certificate is accessible (same organization, directory service, or previously exchanged)
- Regular communication with established recipients

Note: In this scenario, SendCUIEmail is **not needed**—use Outlook's native S/MIME instead.

6. Option 2: Why SendCUIEmail Uses Password-Based Encryption

SendCUIEmail uses password-based (symmetric) encryption rather than certificate-based encryption because it is designed for recipients who **do not have** PIV/CAC or whose certificates are not accessible.

Why Out-of-Band Requirements Don't Apply:

The NIST SP 800-63B out-of-band requirement applies to **shared secrets** (passwords, symmetric keys). Certificate-based encryption uses **asymmetric cryptography**—no shared secret exists:

Encryption Type	What's Transmitted	Out-of-Band Needed?
Password-based	Shared secret (password)	Yes—per NIST 800-63B
Certificate-based	Public key only	No—public keys aren't secret

How Certificate-Based Encryption Works:

- Sender encrypts using recipient's **public certificate** (can be sent via email—not secret)
- Only recipient can decrypt using their **private key** (never leaves PIV/CAC card)
- **No shared secret** exists, so no out-of-band transmission is required
- Provides non-repudiation and authentication

Standards:

- **S/MIME** (Secure/Multipurpose Internet Mail Extensions)
- **OpenPGP** (Pretty Good Privacy)
- Both are referenced in NIST SP 800-45 for email security

When to Use Certificate-Based Encryption:

- Recipient has PIV/CAC card with valid certificate

- Certificate can be obtained from directory service or key server
- Organization has PKI infrastructure in place
- Regular communication with same recipients

7. When SendCUIEmail Is Appropriate

SendCUIEmail's password-based encryption is designed for situations where certificate-based encryption is **not feasible**:

- Recipient does not have PIV/CAC card
- Recipient's certificate is not accessible (different organization, no directory access)
- One-time or infrequent communication with external parties
- Recipient's email client does not support S/MIME
- Emergency situations where certificate exchange cannot be completed in time

8. Hybrid Approach: S/MIME Encrypted Password Email

A compliant alternative uses **both** encryption methods:

- (a) **Email #1:** Files encrypted with SendCUIEmail (password-based AES-256)
- (b) **Email #2:** Password in message body, **email itself S/MIME encrypted** with recipient's PIV/CAC certificate

Why This Is Compliant:

- The password (human-readable/enterable) is protected by asymmetric encryption
- **Encrypted** with recipient's public certificate—only they can decrypt
- **Signed** with sender's private key (from sender's PIV/CAC)—proves authenticity
- Same channel (email) is acceptable when the secret is cryptographically protected
- The encrypted files in Email #1 can be forwarded, stored, or used on systems without S/MIME

When to Use This Approach:

- Recipient has PIV/CAC but may need to forward/store files on non-S/MIME systems
- Need audit trail of password delivery (S/MIME provides non-repudiation)
- Organization policy requires all CUI via email be S/MIME encrypted

Outlook Implementation: When composing the password email, click "Sign" and "Encrypt" in Outlook to S/MIME sign and encrypt before sending.

Future Enhancement: PIV/CAC certificate access is already implemented in the PDF-Signer project. This functionality could be integrated into SendCUIEmail to automate S/MIME signing/encryption of the password email when PIV/CAC is available.

9. Password Transmission Without S/MIME

When **not** using S/MIME encryption for the password email, the password **MUST** be transmitted via an out-of-band channel per NIST SP 800-63B:

Method	Compliant?	Notes
Phone call (PSTN)	Yes	Proves possession of phone number
SMS text message	Yes	Proves possession of SIM card
In-person	Yes	Direct verification of identity
Separate email	No	Does not prove device possession
Same email	No	No separation at all

Note: SendCUIEmail generates a `Password_Email_*.msg` draft as a **convenience feature** for operational flexibility. Users should understand this does **not** meet NIST out-of-band requirements. The tool displays warnings to this effect.

10. Implementation in SendCUIEmail

The tool implements the following to guide users toward compliant behavior:

- **Primary guidance:** “Share password via phone, text, or in-person”
- **Secondary option:** Password email draft with security warning
- **Warning in password email:** Explicitly states separate channel is preferred
- **No auto-send:** All email drafts require manual recipient entry and review

11. Decision

- (a) **Certificate-based encryption** (S/MIME with PIV/CAC) is the preferred method when feasible
- (b) When using password-based encryption, passwords **SHALL** be transmitted via out-of-band channel (phone, SMS, in-person)
- (c) The password email feature is retained for operational flexibility but includes prominent warnings about NIST non-compliance
- (d) Documentation clearly states these requirements

12. References

- NIST SP 800-63B: Digital Identity Guidelines - Authentication and Lifecycle Management
- NIST SP 800-57 Part 1: Recommendation for Key Management
- NIST SP 800-45: Guidelines on Electronic Mail Security
- NIST SP 800-171: Protecting Controlled Unclassified Information
- FIPS 201: Personal Identity Verification (PIV) of Federal Employees and Contractors